Entra Cloud Sync provisioning to AD with AD object enforcement

Consolidated findings: keeping passwordless sign-in to Active Directory working for cloud-first users

Scope. Microsoft Entra Cloud Sync user provisioning from Entra ID to AD (preview) combined with AD object enforcement (preview), for users created in Entra ID or converted to cloud source of authority. These users sign in passwordless (Windows Hello for Business / FIDO2 via Cloud Kerberos Trust, AVD / RemoteApp SSO).

Evidence levels. Documented = Microsoft documentation, protocol specification or Microsoft source code. **Observed** = lab observation with the preview. **Inferred** = derived; the verifying script is named.

1. Executive summary

- Provisioned users have **no usable AD password** (no password writeback) and are meant to use passwordless Kerberos. An **expired AD password blocks** FIDO2 and WHfB Cloud Kerberos Trust sign-in (Documented).
- **SCRIL** ("Smart card is required for interactive logon") prevents the computed password-expired state (Documented, MS-ADTS). Cloud Sync does not apply a direct `userAccountControl` mapping (Observed), so SCRIL is set by an allow-listed job.
- **Automatic rolling** of SCRIL secrets is enabled by default in domains installed at functional level 2016 or later. It becomes due at `pwdLastSet` + `maxPwdAge`, is excluded by *password never expires*, sets `pwdLastSet`, and is tied to PKINIT in the specification. Whether Cloud Kerberos Trust triggers it is **open** and is measured by the toolkit.
- **AD object enforcement** blocks LDAP changes to marked objects for every identity not on the allow-list, Domain Admins included. Every writable DC must run the engine. One stale SID makes the policy fail to load.
- Microsoft's `Set-CloudSyncSOAPolicy.ps1` **cannot switch the enforcement mode** as documented (F1). The toolkit switches the mode by writing the policy's `keywords` attribute, with pre-checks.

2. Architecture and control flow

Component	Role	Write access to marked objects
Cloud Sync provisioning agent (agent gMSA)	Creates / updates provisioned users and groups, sets msDS-ObjectSoa = Cloud	Allowed (allow-list)
SCRIL job (job gMSA, scheduled tasks "Enforce SCRIL", "Rotate SCRIL secret")	Sets SCRIL, rotates secrets, test actions on the TestUser	Allowed (allow-list); ACL limited to userAccountControl + Reset Password
Break-glass account (disabled)	Emergency changes if cloud provisioning is unavailable	Allowed (allow-list), enable only in an emergency
Administrators, helpdesk, other scripts	Changes are made in Entra ID instead	Blocked in Enforced mode
Enforcement engine on every writable DC	Evaluates the SOA policy (CN=Cloud: keywords = mode, msDS-Settings = allow-list) on every LDAP write	-
Entra Kerberos / Cloud Kerberos Trust	Partial TGT from Entra ID, exchanged at a writable DC for a full TGT (AVD SSO, file shares)	-

3. Key findings

#	Finding	Evidence
K1	No password writeback for Entra ID → AD provisioning; passwordless Kerberos (WHfB / FIDO2 with Cloud Kerberos Trust) is the intended path.	Documented [R1, R2]
K2	An expired AD password blocks FIDO2 and WHfB Cloud Kerberos Trust sign-in.	Documented [R10]
K3	The computed password-expired bit is never set while SCRIL or PNE is set.	Documented [R14]
K4	The default user mapping writes msDS-ObjectSoa = Cloud; provisioned users are marked automatically.	Documented [R5, R6]
K5	Enforced mode blocks LDAP modify, modify DN and Recycle Bin restore for non-allow-listed identities; add and delete remain allowed (preview). A writable DC without the engine lets changes through.	Documented [R6]
K6	One unresolvable SID in msDS-Settings: the whole policy fails to load. Maximum 64 SIDs.	Documented [R6]
K7	A direct userAccountControl mapping is not applied by the agent; only accountDisabled toggles bit 0x2, other bits (SCRIL) are preserved.	Observed
K8	"User cannot change password" is an ACL (deny ACEs on Change Password), not settable through userAccountControl.	Documented [R15]
K9	Automatic rolling needs: rolling attribute TRUE, DFL ≥ 2016, SCRIL, no PNE, expired password. It writes new random unicodePwd / dbcsPwd and sets pwdLastSet.	Documented [R13]
K10	MS-SAMS refers to PKINIT (MS-PKCA) for rolling; Cloud Kerberos Trust does not use PKINIT against the DC, so rolling via CKT is unverified.	Inferred → Test-ScrilBehavior.ps1 RollingObserve
K11	Setting SCRIL resets the password to a random value. A pwdLastSet update is not documented; it was observed unchanged in one UI test.	Documented [R17] / Observed → UiObserve, Matrix
K12	If toggling SCRIL does not move pwdLastSet, it does not postpone the rolling window → RotationMethod RandomReset when rolling is enabled.	Inferred (K9 + K11)
K13	Domains installed at functional level 2016 or later have the rolling attribute enabled by default.	Documented, third party [R18] → Inventory
K14	The KIR "Feature Preview" enablement package sets several feature IDs at once (enabledList).	Observed
K15	AVD SSO: the default lock behavior (disconnect) supports passkeys / FIDO2; the remote lock screen does not.	Documented [R12]

4. SCRIL, password expiry and automatic rolling

User state	PE bit	Automatic rolling	Secret changes through	Risk for passwordless sign-in
no SCRIL, no PNE	after maxPwdAge	-	-	**High** - blocked after expiry (K2)
no SCRIL, PNE	never	-	-	Low, but a usable password may exist
SCRIL, no PNE, rolling off	never	-	SCRIL set / job	Low
SCRIL, no PNE, rolling on	never	due at pwdLastSet + maxPwdAge	DC rolling (PKINIT) / job	Depends on K10 - measure
SCRIL + PNE	never	excluded (K9)	job only	Low - rotation purely job-driven

> **Recommended target state.** SCRIL on every provisioned user, plus job rotation with `RotationMethod = RandomReset` and `RotationDays` < effective `maxPwdAge`, so that users never reach the rolling window. Alternatively SCRIL + PNE. Rely on DC rolling only if the rolling observation passes. "User cannot change password" adds practically nothing when SCRIL is set, because nobody knows the password.

5. Upstream issues in Microsoft's scripts and documentation

Examined versions (retrieved 2026-10-19): Set-CloudSyncSOAPolicy.ps1, AzureAD/EntraIDGovernance, file commit `3f03ef2d5e63ffd084ec4b9deac495e3bf1215e6` (2026-05-26), SHA-256 `d23e36a8...0f0baf`; Check-CloudSyncSOAPolicy.ps1, commit `0afc4332aa9f73b22607854cf4a7c77b608fc7aa` (2026-06-04); documentation "Configure AD user and group enforcement in Microsoft Entra Cloud Sync (preview)", docs commit `e12ee33874afa8164c88fed97789e51592c56c32`, ms.date 2026-08-11, last updated 2026-08-28.

ID	Documentation says	Script actually does	Toolkit handling
F1 defect	"To change the mode, run Set-CloudSyncSOAPolicy.ps1 again with the new value for -EnforcementMode."	If CN=Cloud exists: prints "SOA policy 'Cloud' already exists. No changes were made." and returns (lines 153-161). keywords is written only on creation (line 166). **Mode switch and emergency rollback are not possible with the documented method.**	Initialize-SoaEnforcement.ps1 -Step SetMode writes keywords directly; pre-checks, replication wait, policy-load events
F2 design	The PDCe creates the SOA-Policies container automatically after update and enablement.	Creates the container itself if missing (lines 142-151) - masks an inactive engine on the PDCe.	Test-SoaEnforcementPrereqs.ps1 reports the originating DC of the container
F3 docs ↔ code	Check-CloudSyncSOAPolicy.ps1 "reports whether the AD object enforcement policy is enabled on that domain controller".	Reads only domain-wide objects and the local value "2 Security Events"; no ntdsai.dll, KIR or policy-load check.	Test-SoaEnforcementPrereqs.ps1; Initialize -Step Verify (event 3095 per DC)
F4 assumption	-	Check script expects the agent gMSA at CN=provAgentgMSA,CN=Managed Service Accounts (line 34); otherwise the SID check is skipped.	AllowList resolves the gMSA from the agent service on every agent host
F5 terminology	"Set the Security Diagnostics value to 1 in the registry."	Actual value: NTDS\Diagnostics\"2 Security Events" (Check script lines 180-191).	Set-NtdsSecurityDiagnosticsGpo.ps1
F6 limitation	"adds the provisioning agent's gMSA SID to the policy's allow list"	Adds only the local agent's gMSA; no option for further SIDs (break-glass via ADSI Edit).	AllowList: all agents, job gMSA, break-glass, SID validation, 64-SID limit

6. Toolkit and validation plan

Step	Script	Result
Pre-flight	Test-SoaEnforcementPrereqs.ps1	Per-DC matrix: OS, ntdsai.dll, KIR override + RSoP, restart, container per DC + origin, replication
Event logging	Set-NtdsSecurityDiagnosticsGpo.ps1	Events 3095 / 3097 / 3098 in the Directory Service log on all DCs
Identities	Initialize-SoaEnforcement.ps1	Job gMSA, least-privilege ACLs, break-glass, validated allow-list, SCRIL job, Verify, SetMode
Impact	Get-SoaEnforcementImpact.ps1	Marked objects and writers that would be blocked (Security log evidence)
SCRIL behavior	Test-ScrilBehavior.ps1	Inventory, UI observation, 17-step matrix with derived answers, rolling observation
Operations	Invoke-ScrilJob.ps1 / Watch-CloudUserPasswordless.ps1	SCRIL + metadata-verified rotation; daily monitoring (exit 0/1/2) and validation tests

Open questions

- Does a Cloud Kerberos Trust sign-in trigger automatic rolling, and does sign-in keep working after the rolling window? (RollingObserve)
- Does setting or clearing SCRIL update pwdLastSet in addition to the secret? (UiObserve, Matrix)
- Is the allow-list evaluated for group SIDs in the access token? (not tested; only account SIDs are used)
- Effect of enforcement on DC-internal writes and non-LDAP password paths (out of scope of the current tests).

7. References

ID	Source	Version	Retrieved
R1	Overview of Microsoft Entra ID to AD provisioning (learn.microsoft.com)	commit ef0fab3f, upd. 2026-09-24	2026-10-15
R2	Tutorial: Govern access to an on-premises app (preview)	commit e12ee338, upd. 2026-08-28	2026-10-15
R3	How provisioning to AD works (preview)	commit 10c83918, upd. 2026-08-28	2026-10-15
R5	Configure Microsoft Entra ID to AD provisioning (preview)	commit e12ee338, upd. 2026-09-24	2026-10-15
R6	Configure AD user and group enforcement (preview)	commit e12ee338, ms.date 2026-08-11	2026-10-15 / 10-19
R7	Set-CloudSyncSOAPolicy.ps1 (github.com/AzureAD/EntraIDGovernance)	commit 3f03ef2d (2026-05-26)	2026-10-16 / 10-19
R8	Check-CloudSyncSOAPolicy.ps1 (same repository)	commit 0afc4332 (2026-06-04)	2026-10-16 / 10-19
R10	Passwordless security key sign-in to on-premises resources - Known behavior	n/a	2026-10-15
R12	Configure single sign-on for Azure Virtual Desktop	commit 9e91f2c9, upd. 2026-06-24	2026-10-15
R13	[MS-SAMS] 3.3.5.7.2 Normative Specification	current at retrieval	2026-10-15 / 10-19
R14	[MS-ADTS] 3.1.1.4.5.17 msDS-User-Account-Control-Computed	upd. 2026-08-24	2026-10-15
R15	Use the UserAccountControl flags (KB 305144)	n/a	2026-10-15
R16	Security Focus: Resetting SCRIL (Microsoft blog archive)	archived	2026-10-15
R17	Expire Passwords On Smart Card Only Accounts (secureidentity.se)	n/a	2026-10-19
R18	Automatically change passwords for SCRIL / WHfB accounts (gradenegger.eu)	n/a	2026-10-19
R19	DISA STIG V-243476, Active Directory Domain	STIG 2026-02-11	2026-10-15

Full list with URLs: README.md, section "References".